

Data Backup & Retention Policy

1. Purpose

This policy defines Summit IT Services' requirements for backing up business data and retaining records for appropriate periods. Adequate backups protect against data loss from hardware failure, ransomware, accidental deletion, and disasters. Retention requirements ensure that Summit IT Services meets legal, regulatory, and contractual obligations while avoiding unnecessary long-term storage of data that should be deleted.

2. Scope

This policy applies to:

- All business data created, received, or processed by Summit IT Services employees and systems.
- All IT systems that store or process company data, including Microsoft 365 (Exchange Online, SharePoint, OneDrive, Teams), on-premises servers, AWS cloud services, SaaS applications, and local endpoint storage.
- All employees who create, store, or are responsible for company data.
- All contractors who create data on Summit IT Services systems.

3. Policy Statements

3.1 Data Storage Locations - Employee Responsibilities

3.1.1 Employees must store all business data in IT-approved, backed-up locations. The primary approved storage locations are:

Platform	Use Case	Backup Coverage
OneDrive for Business	Individual work files, documents	Yes - Microsoft 365 backup
SharePoint / Teams	Shared team files, project collaboration	Yes - Microsoft 365 backup
Exchange Online (Outlook)	Email and calendar	Yes - Microsoft 365 backup
AWS S3 (IT-managed buckets)	Application data, system data	Yes - S3 versioning + cross-region replication
SummitDesk (ServiceNow)	ITSM records, CMDB	Yes - vendor SaaS backup

3.1.2 Data stored exclusively on local device hard drives or desktops is **not backed up** by IT. Employees must ensure all business-critical files are saved to OneDrive or SharePoint. Intune and Jamf policies enforce OneDrive Known Folder Move (KFM) on Windows, which automatically syncs Desktop, Documents, and Pictures folders to OneDrive.

3.1.3 Data stored on personal devices, personal cloud storage, or unauthorized SaaS tools is not covered by any IT backup and may be permanently lost. This is also a violation of the Acceptable Use Policy (POL-001).

3.2 Backup Schedule and Recovery Objectives

Summit IT Services maintains the following backup and recovery standards for IT-managed systems:

System	Backup Method	Backup Frequency	Retention Period	RTO Target	RPO Target
Microsoft 365 (Exchange, SharePoint, OneDrive, Teams)	Microsoft 365 native recycle bin + third-party M365 backup (Veeam)	Continuous / Daily snapshot	90-day recycle bin; 1-year backup archive	4 hours	24 hours
AWS production workloads	AWS Backup (automated daily snapshots, EBS, RDS, S3 versioning)	Daily	30 days (daily), 12 months (monthly)	4 hours	24 hours
On-premises servers	Veeam Backup & Replication to on-site NAS + off-site replication	Daily full + hourly incremental	14 days on-site; 90 days off-site	8 hours	1 hour
SummitDesk (SaaS)	Vendor-managed backup	Vendor SLA	Per vendor agreement	Per vendor SLA	Per vendor SLA

Endpoint (OneDrive KFM)	Microsoft 365 OneDrive versioning + M365 backup	Continuous sync	90-day version history; 1-year archive	Self-service restore; 4 hours L2 assist	Near-real-time
-------------------------------	--	--------------------	--	--	----------------

3.2.1 Recovery Time Objective (RTO): The maximum acceptable time to restore a system or data after a failure event. **3.2.2 Recovery Point Objective (RPO):** The maximum acceptable data loss measured in time (e.g., RPO of 24 hours means at most 24 hours of data may be lost).

3.2.3 Backup integrity is verified monthly by L3 Engineering through test restores. Annual disaster recovery (DR) exercises test full system recovery and are documented in the DR report submitted to the CISO.

3.2.4 Backup failures are monitored automatically; alerts are sent to the L3 Engineering on-call queue. Failed backups must be investigated and resolved within 24 hours.

3.3 Data Retention Schedule

Data must be retained for the minimum period required by business, legal, or regulatory requirements, then disposed of securely. The following retention schedule applies:

Data Category	Retention Period	Basis
Employee email (general business)	7 years	Legal / regulatory default
Financial and accounting records	7 years	IRS / SOX requirements
Client contracts and engagement records	7 years after engagement end	Legal requirement
Human resources records (personnel files)	7 years after separation	Employment law
Payroll records	7 years	FLSA / IRS
IT security logs (firewall, Okta, CrowdStrike, VPN)	1 year active; 2 years archived	Security operations standard
Incident and change management tickets (SummitDesk)	5 years	IT governance
Meeting recordings (Teams / Zoom)	90 days (unless designated for retention)	Business default

Slack messages	1 year	Business default
General business documents (non-contract)	5 years	Business default
Marketing and public communications	3 years	Business default
Regulated personal data (PII, PHI)	Per applicable regulation (HIPAA, CCPA, GDPR) + 1 year	Regulatory
Data subject to legal hold	Until hold is released	Legal requirement (see 3.4)

3.3.1 Data must not be deleted before its minimum retention period has elapsed unless a valid legal, privacy (data subject request), or business exception applies.

3.3.2 Data must not be retained beyond its retention period without a documented business justification. Retention beyond the scheduled period increases legal discovery risk and storage cost.

3.3.3 Employees with questions about the retention schedule for specific data should contact the IT Service Desk or Legal.

3.4 Legal Holds

3.4.1 A **legal hold** (also called a litigation hold) is an order to preserve specified data beyond its normal retention period because of pending or anticipated litigation, investigation, audit, or regulatory proceeding.

3.4.2 Legal holds are initiated by the Legal team. When a hold is issued, the Legal team will: 1. Notify the IT Security & Compliance team of the hold scope (custodians, date range, data types). 2. IT will apply a Microsoft Purview Compliance Center hold on the affected mailboxes, OneDrive accounts, and SharePoint sites. 3. Affected employees will receive notification that their data is subject to hold (unless Legal determines notification would prejudice the matter).

3.4.3 Employees who receive a legal hold notification must not delete, modify, or move any data that may be in scope, regardless of its normal retention period. Violation of a legal hold is a serious legal infraction with potential civil and criminal consequences.

3.4.4 Employees must contact Legal immediately if they receive any subpoena, court order, or regulatory inquiry related to company data.

3.5 Secure Data Disposal

3.5.1 When data reaches the end of its retention period or must be deleted for privacy compliance (e.g., GDPR right to erasure request), it must be disposed of securely:

Data Type	Disposal Method
-----------	-----------------

Microsoft 365 files / email	Deleted from SharePoint/OneDrive/Exchange; automatically purged from Microsoft's systems after recycle bin period per M365 backup retention
Local device data	Device wiped per NIST SP 800-88 per POL-010
Physical documents	Cross-cut shredder or locked shred bins (Iron Mountain or equivalent)
AWS data	S3 lifecycle policies for deletion; RDS automated deletion; documented in Change Management
Backup media	Physical destruction or cryptographic erase per NIST SP 800-88

3.5.2 Bulk data deletion requests (e.g., deleting records for a departed client) must be submitted via SummitDesk and approved by IT Security and Legal before execution.

3.5.3 Records of data disposal (certificates of destruction for physical media, deletion logs for electronic data) must be retained for 3 years.

3.6 Employee File Recovery

3.6.1 Employees who accidentally delete files from OneDrive or SharePoint may self-restore from the recycle bin within 93 days. Instructions are available in the IT knowledge base at <https://help.summitit.com>.

3.6.2 For file recovery beyond the recycle bin period, or for email recovery beyond the "Recoverable Items" folder, employees must submit a recovery request via SummitDesk. Recovery from backup is possible within the backup retention window per section 3.2.

3.6.3 Recovery requests are fulfilled by L2 Desktop & Systems within 2 business days for standard requests, or within 4 hours for P2-priority business-critical data loss events.

4. Roles & Responsibilities

Role	Responsibility
All Employees	Save work to approved backed-up locations; comply with retention schedules; comply with legal holds; report accidental data loss immediately
IT Service Desk (L1)	Accept and route data recovery requests; answer retention questions; escalate legal hold issues to Legal/IT Security

IT Security & Compliance	Own policy; enforce retention via Purview policies; apply and monitor legal holds; conduct annual DR exercise; oversee backup audit
L2 Desktop & Systems	Execute data recovery requests; manage OneDrive KFM; support Microsoft 365 backup restores
L3 Engineering	Maintain and monitor backup infrastructure; validate backup integrity monthly; manage AWS Backup and Veeam
Legal	Issue and manage legal holds; advise on regulatory retention requirements; respond to data subject requests
Finance	Retain financial records per schedule; advise on statutory retention obligations

5. Enforcement & Consequences

- **Storing data only on local drives (not backed-up locations):** Written warning; IT assistance to migrate data to OneDrive; mandatory training.
- **Deleting data subject to a legal hold:** Immediate escalation to Legal; HR investigation; potential personal legal liability.
- **Unauthorized bulk deletion of records:** Immediate suspension of data access; HR/Legal investigation.
- **Failure to complete recovery from backup within SLA:** L3 Engineering incident review; escalation to CISO.

6. Exceptions

Exceptions to retention periods (shorter retention for cost or privacy reasons, or longer retention for unique business needs) require: 1. Written justification from the data owner. 2. Legal review for compliance impact. 3. IT Security approval. 4. Documentation in the IT GRC system with an annual review date.

7. Related Documents

- POL-001 - Acceptable Use Policy
- POL-005 - Data Classification & Handling Policy
- POL-009 - Access Control & Least Privilege Policy
- POL-010 - IT Asset Management Policy
- REF-0001 - Summit IT Environment Standards
- Disaster Recovery Plan (restricted; L3 Engineering)
- Microsoft 365 Backup & Recovery Guide (internal wiki)
- Legal Hold Procedure (Legal team)

8. Revision History

Version	Date	Author	Summary of Changes
1.0	2021-06-01	IT Operations	Initial backup and retention policy
2.0	2023-05-01	IT Security & Compliance	Full rewrite; added Veeam M365 backup; formalized retention schedule table; added legal hold procedures
2.1	2024-02-15	IT Security & Compliance	Added OneDrive KFM clause; updated AWS backup details; added Slack 1-year retention
2.2	2025-08-01	IT Security & Compliance	Annual review; updated meeting recording retention to 90 days; added data disposal certificate retention requirement